

Operation Soft Cell

Summary

Operation Soft Cell is a long-running, government-backed cyber-attack against telecom companies across the world. Cybereason disclosed it on June 25, 2019. The attackers are linked to China and tracked by Microsoft as Gallium. Most researchers believe they overlap with APT10. A Swisscom researcher named Markus Neis later found additional links to APT41 and LuckyMouse, though full attribution remains unconfirmed. The researchers concluded with: Simple answer, No Idea.

The target was not passwords or financial data. The attackers wanted Call Detail Records (CDR). CDR logs every phone call: who called whom, when, for how long, the device ID, and which cell tower was used. With this data a foreign government can track anyone on the network without touching their device. The attackers stayed inside victim networks for over a year undetected, then returned four times between 2018 and 2019 each time using slightly changed tools. Cybereason estimated around 200 million people were affected. Industry data shows 30 percent of telcos reported customer data stolen, and 23 percent of critical infrastructure organisations confirmed nation-state intrusions.

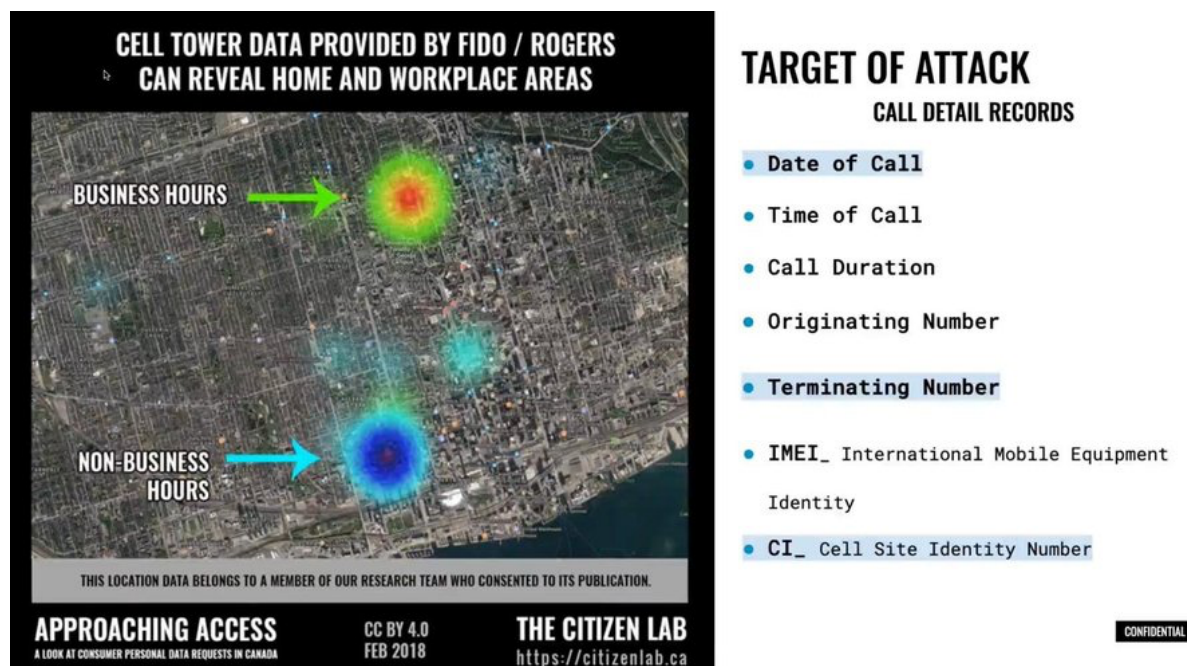


Figure 1: Call Detail Record fields targeted. This data enables precise tracking of any subscriber without device access.

Target - Telecom Companies

There are around 8 billion phone subscribers worldwide. Telecom is classified as critical infrastructure by most governments. Research by the Citizen Lab showed that cell tower logs alone can reveal exactly where a person lives and works by comparing which towers a phone connects to during business hours versus non-business hours. For a foreign intelligence service, bulk CDR access from a major carrier provides mass surveillance capability without any direct device compromise. Telecom companies also tend to have high-value targets on their networks including government agencies and security services who are customers.

Methodology

Four Waves Over Two Years

The attack was described as low and slow. The attackers were inside the victim network for at least one year before any monitoring tool was deployed. Once monitoring began, four waves of activity were identified across 2018 and 2019. Between waves the attackers went quiet but were still likely collecting CDR data silently.

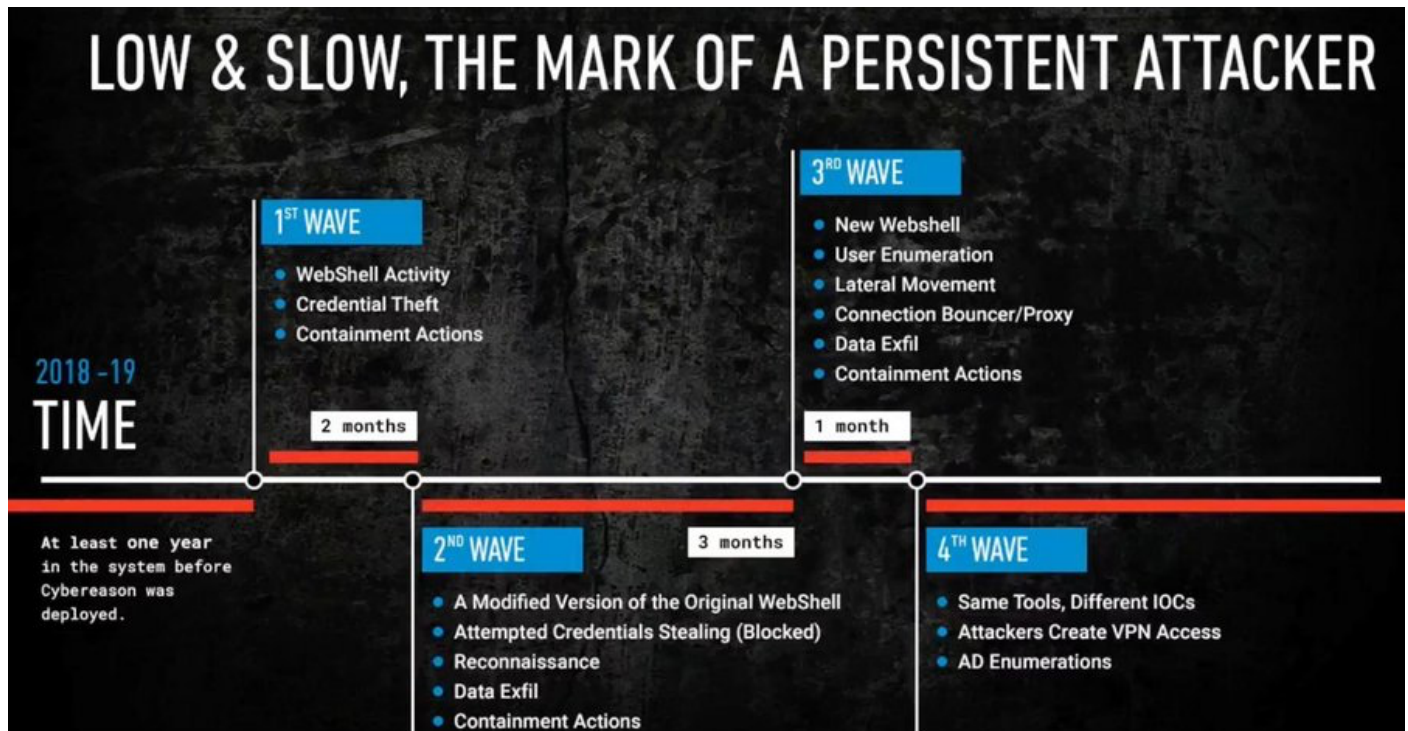


Figure 2: The four waves of attack. Quiet periods between waves were used for continued silent CDR collection.

Wave 1 used a webshell on an internet-facing server, credential theft, and Remote Access Trojan deployment. When Cybereason's solution was installed it detected everything within 48 hours and matched the webshell to China Chopper.

Wave 2 arrived two months later. A modified webshell was placed on an IIS server. Fake admin accounts were created for persistence. NBTScan ran for network mapping. Poison Ivy, hTran, and web shells were used for exfiltration. A Mimikatz credential-theft variant was caught and blocked.

Wave 3 came three months later. The attackers reached Domain Administrator level. They moved laterally using WMI and PsExec. Data exfiltration was attempted via hTran.

Wave 4 arrived one month after that. The same tools were used with new infrastructure to bypass existing blocks. Softether VPN was installed as a persistent backdoor. Active Directory was enumerated. Around 100 GB of CDR data was exfiltrated per session.

Techniques Used to Avoid Detection

Every malware family was disguised inside a legitimate-looking file. A real McAfee binary called mcoemcpy.exe was used to side-load a malicious DLL. A signed Microsoft imaging executable did the same for another payload. The DeployFilter webshell was installed as a native IIS module inside applicationHost.config, making it invisible to endpoint tools that monitor running processes. A stolen code-signing certificate from Whizzimo, LLC made malicious files appear trusted to security software. Security tools looking only at process names or file signatures would not flag any of these.

Technical Findings

A Sting in Memory

The Swisscom investigation began with memory analysis on an injected shellcode sample. Strings from the memory dump revealed C2 addresses and victim-related domains. One string, GOKlqoUwu, returned only three results on Google. One of those was a Joe Sandbox report from June 26, 2019 describing the same string as a named object created by nslookup.exe on a compromised machine. That single detail became the thread connecting everything else.

Poison Ivy and Phantom Creator

Poison Ivy was loaded via RunHelp.exe using DLL side-loading and kept alive with a scheduled task. Its C2 was rosaf112.ddns.net, independently confirmed by Kaspersky researcher Costin Raiu on the same day Cybereason published. Hunting this technique led to the Phantom Creator builder tool, configured with a registry run key named SamsungHelp, filename RunHelp.exe, and file path under AppData in a folder named SamSungHelp. These details matched the Cybereason report exactly, confirming Phantom Creator was used to build those original samples.

PlugX, Trochilus, and Shared Infrastructure

A PlugX sample arrived as a self-extracting RAR file that dropped mcoemcpy.exe, mcutil.dll, and antivir.dat into a ProgramData folder named SamSungHelp. The real McAfee binary mcoemcpy.exe was used to side-load the malicious mcutil.dll. C2 servers were hosted in Hong Kong. CrowdStrike had documented this exact technique in their 2018 Global Threat Report against both Western think tanks and Asian telcos simultaneously.

A Trochilus RAT sample installed files into a folder named Windows Imaging Devices Network Sharing Service. Its C2 domain resolved to the same IP used by PlugX, confirming shared infrastructure between the two. Kaspersky's similarity engine returned a 99 percent match between Trochilus and RedLeaves, a RAT known to belong to APT10.

Gh0st RAT: 270 Samples Found

A Gh0st RAT variant stored its configuration in the file overlay encoded by incrementing each byte by 0x7A then XOR-ing with 0x19. The service was named Microsoft Device Manager to blend in. The unique config pattern allowed researchers to find around 270 related samples on VirusTotal. Most were the

attacker testing their own evasion. A PDB path in one sample led to a project folder named remoteManager, linking further to a Mimikatz variant submitted from Hong Kong.

Stolen Certificate and APT41 Link

The Mimikatz variant was signed with a stolen Whizzimo, LLC certificate issued by Go Daddy. Mandiant had already confirmed this same certificate was used by APT41. Hunting the certificate uncovered a cluster of files submitted from Hong Kong accounts, including configMoudle.exe, a .NET dropper for a modified China Chopper webshell called DeployFilter. It registered a native IIS module in applicationHost.config, giving the attacker access to every HTTP request on the server. Mandiant documented this same IIS technique as CHIPSHOT.

MITRE ATT&CK TECHNIQUES USED

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Exploit Public-Facing Application	Command-line interface	Web Shell	Valid Accounts	DLL-side Loading	Credential Dumping	System Network Configuration Discovery	Windows Admin Shares	Data From Local System	Remote File Copy	Data Compressed	
	Windows Management Instrumentation	Create Account	Web Shell	Indicator Removal from Tools		Remote System Discovery	Pass the Hash	Data Staged	Connection Proxy	Exfiltration Over Command and Control Channel	
	PowerShell			Obfuscated Files or Information		Account Discovery	Remote File Copy	Input Capture			
				Masquerading		Permission Groups Discovery					

Figure 3: MITRE ATT&CK technique mapping across the full attack chain from initial access to exfiltration.

Analysis

The tools, infrastructure, certificates, and victim data all point to Chinese state-sponsored activity connected to APT10, APT41, and LuckyMouse. But whether these are one group using different names, separate teams sharing tools, or contractors for different clients within the same intelligence structure is not conclusively established. The v2.0 Swisscom findings added that a second Chinese-linked actor appears to have shared access to at least one victim at the same time as the primary Soft Cell operators, suggesting multiple groups may target the same high-value networks independently.

Despite their sophistication the attackers made operational mistakes. They left victim-related domains inside shellcode memory. They reused C2 servers across different malware families. They uploaded builder tools and test samples to VirusTotal from Hong Kong accounts. These mistakes are what gave researchers the connecting threads between campaigns.

Four waves with quiet periods in between is the pattern of a long-term collection operation, not a destructive attack. The 100 GB CDR exfiltration per session in Wave 4 shows the attackers had fully mapped the telecom backend and were running structured database queries, not grabbing files at

random. The LuckyMouse connection came through VirusTotal metadata where the same victim company that submitted Soft Cell malware later submitted an NDISProxy driver attributed to LuckyMouse, showing that high-value telcos are targeted by multiple state groups simultaneously.

The attackers were inside the network for over one year before monitoring was deployed. Once proper monitoring was in place, Wave 1 was detected within 48 hours. That gap between one year of undetected access and 48-hour detection is entirely explained by the absence of monitoring tools. Good detection works when it is deployed. The challenge for telecom companies is accepting that these attackers will get in eventually and building the capability to find them fast when they do.

Recommendation

Do not wait for an alert. Start by checking servers running both email and web services on the same machine since this is a configuration the attackers specifically exploited. Review operational network segments separately as they are typically less monitored than corporate IT. Check the IIS applicationHost.config file on all web servers for any registered native modules with unusual paths or unsigned DLL files. Review all scheduled tasks and registry run keys for anything named after consumer hardware brands or generic Windows service names that do not match real installed software. Flag any process running from AppData or ProgramData folders with suspicious naming.

Flag DNS queries going to dynamic DNS services such as .ddns.net or .myftp.biz. Alert on unexpected VPN software installations, particularly Softether VPN. Monitor for large volumes of compressed data leaving the network through unusual ports or destinations. Since Wave 4 exfiltrated 100 GB of CDR data per session, setting hard limits and alerts on CDR database query volumes and data export sizes would directly reduce the impact of this type of attack. Consuming threat intelligence feeds covering known Chinese state-sponsored infrastructure will allow defenders to block known bad IP addresses and domains before they are actively used.

Active monitoring must cover endpoint behaviour, network traffic, server configuration files, and authentication logs at the same time. Threat hunting should run on a regular schedule and not only after an alert fires. Incident response plans should be tested and updated so the team can act quickly when a compromise is found. The 48-hour detection time after deployment shows that well-configured tools and a trained team can work fast. The investment pays off.

Since CDR data is the primary target, controls should be applied directly at the database level. Limit which accounts and systems can run large CDR queries. Log and alert on queries that pull more than a defined threshold of records. Apply data loss prevention controls on CDR exports. Audit CDR database access logs regularly. These controls would not have stopped the initial compromise but they would have significantly reduced what the attackers could take during Waves 3 and 4.